

SDP



PR Trust Stack

Evidence and Authority Before Merge

Give every pre-merge signal a role, an owner, and a governed path to action

"Which signals should advise, which should block, and who accepts residual risk?"

Classify evidence before automation acquires authority.

Every signal needs a role, owner, and escalation path.

Developer

Disposition findings with code, tests, constraints, or escalation



Team Lead

Decide which approvals count and which checks can block



Platform and Security

Own narrow gates, exceptions, and protected-domain escalation



4 committed artifacts

One independently inspectable teaching path

Evaluate → active

Observe impact before granting merge authority

1 named human owner

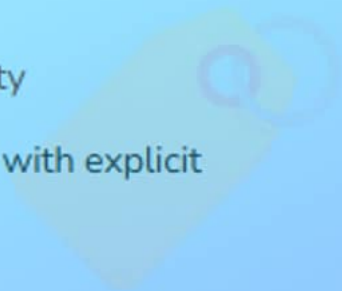
Residual-risk acceptance never becomes anonymous

PART 1

Classify Signals

Define role before authority

Accept, reject, or escalate with explicit ownership

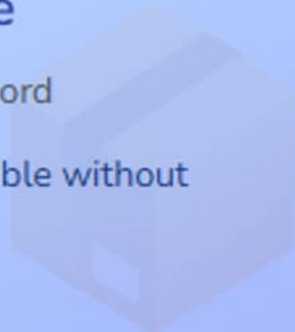


PART 2

Assemble Evidence

Commit one reviewable record

Keep four artifacts inspectable without overstating validation

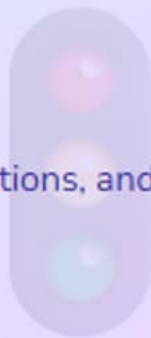


PART 3

Promote Gates

Move evaluate to active

Use evidence, ownership, exceptions, and rollback

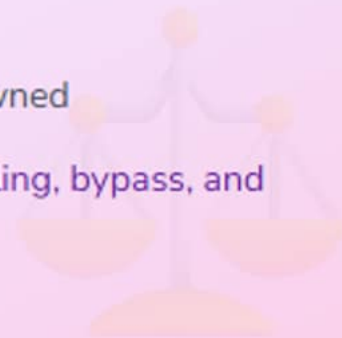


PART 4

Govern Risk

Keep authority human-owned

Separate enablement, billing, bypass, and residual risk



Click any section to jump directly there

Classify Before Authority

Define approval semantics, scope, counting, and accountability before a signal can affect merge.



Advise

Human dispositions decide relevance



Approve

Policy decides whether it counts



Block

Active rules enforce narrow proof

Signal contract

↳ Accept · reject · escalate

Give Every Signal One Semantic Role

Generation and authority are separate decisions

Review note	Contextual hypothesis; developer or reviewer dispositions it	ADVISORY
Approval	Counts only inside an explicitly enabled approval policy	POLICY
Tests	Reproducible status enforced through required checks	BLOCKING
Coverage	Delta or threshold enforced only by an active ruleset	BLOCKING
Quality	Rule semantics determine reproducibility and response	MIXED
Residual risk	Named qualified human authorizes merge or stop	HUMAN

A tool can generate a signal without receiving authority

Treat Advisory Findings as a Hypothesis Queue



Accept

Finding fits the repository

Change code

Add regression evidence

Record the disposition



Reject

Repository evidence invalidates it

Cite the test

Link the constraint or ADR

Keep disagreement inspectable



Escalate

Finding crosses an owned boundary

Name security or architecture owner

Stop silent acceptance

Retain the decision

Preview Approval Creates Three Human Policy Questions



Scope

Which repositories inherit or override enablement?



Counting

Which required-approval rules recognize a Copilot approval?



Accountability

Which human still owns domain and residual-risk acceptance?



A configured count does not transfer legal, security, product, or operational accountability.

Assemble One Reviewable Evidence Record

Join four committed artifacts while distinguishing teaching examples from tenant-validated configuration.



Four Artifacts

Commit the complete teaching path



Provenance

Retain distinct evidence semantics



Validation

Confirm schemas in the target tenant

Committed evidence

↳ Inspectable does not mean deployable

Four Committed Artifacts, Two Kinds of Confidence



Review Instructions

Teaching artifact: focuses advisory review; never grants enforcement authority



Coverage Workflow

Teaching artifact: inspectable least-privilege Cobertura contract; validate runtime



Evaluate Ruleset

Teaching artifact: models observation; validate current target-tenant schema



Trust Record

Teaching artifact: captures disposition, gate state, override, and human owner

The Workflow Teaches a Contract, Not a Deployment Claim

examples/.github/workflows/pr-evidence.yml

```
permissions:
  contents: read
  code-quality: write

- run: pytest --cov=src --cov-report=xml:coverage.xml
- uses: actions/upload-code-coverage@v1
  with:
    file: coverage.xml
    label: code-coverage/pytest
```

Teaching Artifact

Committed, reviewable, and independently inspectable

Target Validation

Run tests; confirm upload, percentage, delta, and permissions

Repository Boundary

Validate aggregation before sharing a polyglot threshold

One Surface Does Not Mean One Evidence Type

Deterministic Rule

Expected reproducibility

Same code and rule version

Best use

Enforce a narrow known condition

Response

Fix, tune, or use governed bypass

AI-Assisted Finding

Context dependent

Can vary with model and context

Best use

Surface semantic or maintainability risk

Response

Accept, reject, investigate, or escalate

 The trust record retains provenance even when the product surface combines findings.

Promote Proven Signals

Make activation an explicit policy event backed by evidence, ownership, exceptions, and rollback.



Evaluate

Observe impact



Decision

Review evidence



Active

Enforce deliberately

Peak decision

↳ Observed threshold → active merge gate

Authority Is Earned in Stages

The team chooses sample size and tolerance; evidence decides promotion

1

Evaluate

Observe would-block outcomes on representative pull requests



2

Classify

Separate valid failures, missing evidence, mismatch, and noise



3

Decide

Record threshold rationale, owner, exception, and rollback



TARGET

4

Active

Block matching merges when the proven condition fails



No representative evidence means no promotion

The Evaluate Ruleset Is Inspectable, Not Tenant-Authoritative

examples/rulesets/pr-trust-stack.evaluate.json

```
{
  'name': 'PR trust stack',
  'target': 'branch',
  'enforcement': 'evaluate',
  'conditions': { 'ref_name': {
    'include': ['refs/heads/main']
  } },
  'rules': [{ 'type': 'code_quality',
    'parameters': { 'minimum_coverage_percentage': 80 }
  }]
}
```

Teaching Artifact

Shows scope, candidate threshold, and observation state

Target Tenant

Generate or export the current schema through supported UI or API

Validation Proof

Retain would-block results from representative pull requests

One Field Grants a Proven Threshold Merge Authority

The smallest configuration change carries the largest governance consequence

EVALUATE
→ ACTIVE

observed impact becomes an enforced merge gate

GitHub Code Quality ruleset enforcement states

Evidence Window

Representative pull requests classified by outcome

Threshold Rationale

Observed risk and remediation justify the number

Named Owner

Human policy owner authorizes promotion

Rollback Condition

Agreed unexplained-block tolerance returns the rule to evaluate

 Activation is a human-owned policy event, not a configuration convenience.

The Same Regression Changes Consequence, Not Evidence

Observation proves behavior before enforcement changes merge authority

Evaluate Mode

- 1 Coverage falls below 80%
Cobertura delta is visible
- 2 Rule reports would block
Merge remains possible
- 3 Team classifies cause
Valid, missing, mismatch, or noise
- 4 Pilot record grows
No authority granted yet



Observed impact; no merge block

Active Mode

- 1 Coverage falls below 80%
The same evidence is visible
- 2 Rule blocks merge
Matching condition is enforced
- 3 Developer remediates
Add test or invoke governed bypass
- 4 Decision is retained
Status, rationale, and owner remain visible



Proven threshold; active merge gate

Same PR evidence · different enforcement authority

Promotion Requires a Complete Activation Record



Evidence Window

Sample and outcome classes chosen by the team, then retained



Threshold Rationale

Why this condition represents real, remediable risk



Exception Path

Named bypass roles, required rationale, expiry, and escalation



Rollback Condition

Sustained unexplained blocks above agreed tolerance

PART 4

Keep Authority Human-Owned

Keep product access, commercial terms, bypass authority, and risk acceptance as distinct decisions.



Enablement

Observe controls in the tenant



Billing

Use live commercial sources



Risk Owner

Name who may merge or stop

Authority boundary

↳ Automation informs · humans own risk

Keep Product Boundaries Separate

Observed tenant settings and live billing sources outrank copied assumptions

Review

Enablement does not turn comments into blocking checks

COPILOT

Approvals

Preview counting needs explicit scope and policy ownership

PREVIEW

Quality

Enablement, findings, coverage, and rulesets are independent

CODE QUALITY

Workflow

Runner consumption remains separate from product entitlement

ACTIONS

Billing

Use live product pages plus organization usage data

LIVE SOURCE

A rollout record captures observed controls from the target tenant

Bypass and Residual Risk Need Named Human Authority

Governed Bypass

Named role

Permission is narrow and explicit

Required rationale

Failing evidence stays attached to the PR

Time bound

Compensating validation and follow-up have an expiry

Review frequency

Repeated bypasses challenge the rule or delivery system

Residual-Risk Acceptance

Qualified owner

Code, security, privacy, payments, or platform

Human judgment

Business intent and threat model remain owned

Merge or stop

The decision includes rationale and escalation

No anonymous authority

Automation informs but never accepts remaining risk

Apply the Contract to One Real Pull Request

✗ Choose the PR

Changes production behavior

Has meaningful test coverage

Crosses a named domain boundary

💡 Build the Record

Accept one material finding

Reject one with repository evidence

Capture one evaluated or active gate result

✓ Validate Authority

Reviewer explains every signal role

Bypass path names an authorized human

Residual-risk owner records merge or stop

1 PR

observable trust contract

✓ Done means the timeline shows evidence, disposition, gate state, and a named human decision.

From Unranked Signals to Governed Merge Authority

Before

Signals arrive without roles

Evidence is scattered

Thresholds activate by intuition

Residual risk is implicit

After

Every signal has semantics

Four artifacts form one record

Evaluate precedes active

A named human owns residual risk

4

committed teaching artifacts

2

explicit enforcement states

1

named residual-risk owner

✓ What You Can Do Today

Today

- Classify one PR signal
- Name its decision owner
- Record one accepted or rejected finding

This Week

- Commit the four teaching artifacts
- Validate target-tenant schemas
- Define an evaluate window

This Month

- Review promotion evidence
- Activate one proven threshold
- Audit bypass frequency and rollback

🔑 Key Takeaway

Automation contributes evidence; people grant authority and accept residual risk.

Review and Quality

[Copilot code review](#)

Review behavior and approval semantics

[Automatic code review](#)

Repository and organization configuration

[GitHub Code Quality](#)

Findings and product boundaries

[Code coverage](#)

Cobertura upload contract

Enforcement and Boundaries

[PR thresholds](#)

Coverage and quality rulesets

[Catch issues before merge](#)

Evaluate-to-active workflow

[Copilot billing](#)

Current Copilot commercial concepts

[Code Quality billing](#)

Current Code Quality commercial concepts



PR Trust Stack

Evidence and Authority Before Merge

4 artifacts

One independently inspectable evidence path

Evaluate → active

Promotion is a governed policy event

Human-owned

Residual risk stays with named authority

Which signal in your repository is ready to earn authority?